

Informe de Pentesting — Actividad A08

Cliente: INSECUR S.A. **Entorno autorizado:** Laboratorios de TryHackMe (sandbox)

Modalidad: Individual

6.1 Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Valentin Moya
DNI	46.399.459
Username TryHackMe	valemoyafernandez
Email institucional	valemoyafernandez@gmail.com
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	Moya-Valentin
Fecha de inicio	07/10/2026
Fecha de cierre	07/10/2026

Nivel 1 (obligatorio): 1. Pentesting Fundamentals — <https://tryhackme.com/room/pentestingfundamentals> ✓ 2. Basic Pentesting — <https://tryhackme.com/room/basicpentestingjt> ✓

Nivel 2 (elección): Vulniversity — <https://tryhackme.com/room/vulniversity> ✓

Entorno de trabajo

Componente	Detalle
Atacante	CachyOS (kernel 7.2.9), herramientas nativas de repositorio
VPN	OpenVPN 2.7.7 contra us-east-1-vpn.vm.tryhackme.com:1194 (UDP)
IP del atacante en THM	192.168.150.209/18 (tun0)
Herramientas	nmap 7.991, gobuster, nikto, hydra 9.7, Metasploit, SecLists, smbclient, rpcclient, curl, tmux
Note	La guía sugiere Kali Linux; se utilizó CachyOS con el mismo conjunto de herramientas, sin alterar el flujo metodológico.

6.2 Pre-pentesting

Alcance del trabajo

Dentro del alcance: únicamente las máquinas y salas asignadas por la cátedra en la plataforma TryHackMe (`pentestingfundamentals` , `basicpentestingjt` y `vulniversity`), atacadas desde la VPN oficial de THM con la IP que la plataforma asigna a la instancia.

Fuera de alcance (excluido): cualquier sistema fuera de las sandboxes de THM, redes de la facultad, cuentas de terceros, servicios en producción y todo activo no autorizado por escrito.

Máquinas trabajadas:

Sala	IP de la instancia	Rol
Pentesting Fundamentals	sin máquina (sala teórica)	—
Basic Pentesting	<code>10.65.141.11</code> → <code>10.67.180.56</code>	objetivo
Vulniversity	<code>10.67.184.183</code>	objetivo

Reglas de Enfrentamiento (ROE)

- Trabajo exclusivamente dentro de las instancias asignadas por THM; al apagar/devolver la máquina el entorno se resetea.
- Sin denegaciones de servicio (DoS/DDoS), sin manipular la VPN fuera de su propósito de acceso, sin atacar el propio cliente THM ni a otros estudiantes.
- Sin extracción ni publicación de flags en claro: solo se registra el hash SHA-256.
- Fuerza bruta limitada: `hydra -t 4 -f` (baja concurrencia), sin wordlists destructivas ni fuzzing de servicios de red.
- Trabajo en horario de actividad académica. Ante cualquier indicio de afectación a un servicio no autorizado, se detiene la actividad y se notifica al docente de inmediato.

Autorización

Declaro que cuento con autorización expresa de la cátedra (cátedra de Seguridad de Sistemas, Facultad de Ciencias Exactas y Naturales) para realizar estas actividades sobre los entornos de TryHackMe indicados en la guía A08. Ninguna técnica será aplicada sobre sistemas reales sin autorización escrita.

Metodología utilizada

Marco elegido: **PTES (Penetration Testing Execution Standard)**, apoyado en la guía **NIST SP 800-115** y en el **OWASP WSTG** para la parte web.

Justificación: PTES define fases claras y verificables (pre-engagement, reconocimiento, escaneo, enumeración, explotación, post-explotación, reporte) que se alinean uno a uno con las fases exigidas por la guía A08 y con las fichas de las salas de THM; OWASP WSTG aporta el detalle técnico para los controles web de Vulniversity y NIST SP 800-115 aporta el rigor del reporte.

6.3 Durante: Hallazgos por fase

H-01 — Listado de directorios en `/development/`

Campo	Valor
ID del hallazgo	H-01
Fase	☒ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	Apache responde con <code>Indexes</code> activo en <code>/development/</code> , exponiendo <code>dev.txt</code> y <code>j.txt</code> : notas internas de los desarrolladores que revelan versiones, nombres de usuario y prácticas de auditoría.
Componente afectado	Apache 2.4.41 — virtual host :80
Categoría (OWASP / CWE)	OWASP A01:2021 Broken Access Control / CWE-548 (Directory Listing)
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	<code>bitacora/gobuster.txt</code> , <code>curl http://<IP>/development/</code>
Herramienta utilizada	gobuster, curl
Impacto en la tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Desactivar <code>Options -Indexes</code> en la directiva del directorio; no versionar archivos de notas en el docroot.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-02 — Share SMB anónimo accesible

Campo	Valor
ID del hallazgo	H-02
Fase	☒ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	El servidor Samba (139/445) permite sesión anónima y expone el share <code>Anonymous</code> con <code>staff.txt</code> , que contiene un aviso interno que menciona a los usuarios Jan y Kay .
Componente afectado	Samba 4.15.13 — share <code>Anonymous</code>

Campo	Valor
Categoría (OWASP / CWE)	OWASP A01:2021 / CWE-200 (Exposure of Sensitive Information)
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	<code>smbclient -L //<IP> -N, smbclient //<IP>/Anonymous -N -c 'get staff.txt'</code>
Herramienta utilizada	smbclient, rpcclient
Impacto en la tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Eliminar shares anónimos o exigir autenticación (<code>valid users</code>); deshabilitar <code>guest</code> en <code>smb.conf</code> .
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-03 — Apache Tomcat 9.0.7 con puerto AJP 8009 expuesto (Ghostcat)

Campo	Valor
ID del hallazgo	H-03
Fase	☒ Escaneo ☐ Reconocimiento ☐ Explotación ☐ Post-explotación
Descripción	El servicio AJP13 (8009) está expuesto sin restricción. Tomcat 9.0.7 (< 9.0.31) es vulnerable a CVE-2020-1938 (Ghostcat) , lectura de archivos a través de AJP. Se confirmó la ejecución del módulo <code>auxiliary/admin/http/tomcat_ghostcat</code> de Metasploit, que logró leer <code>WEB-INF/web.xml</code> ; la travesión de rutas quedó limitada por la normalización de Tomcat, por lo que no se obtuvo lectura arbitraria fuera de la aplicación.
Componente afectado	Apache Tomcat 9.0.7 — AJP/8009
Categoría (CWE)	CWE-200 / OWASP A05:2021 Security Misconfiguration
CVE (si aplica)	CVE-2020-1938
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	<code>msfconsole -q -x "use auxiliary/admin/http/tomcat_ghostcat; set RHOSTS <IP>; run"</code>
Herramienta utilizada	Metasploit, nmap (<code>ajp-headers</code>)

Campo	Valor
Impacto en la tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Actualizar Tomcat a 9.0.31+; bloquear el puerto 8009 en firewall o restringirlo a 127.0.0.1 en server.xml (address="127.0.0.1").
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-04 — Apache Tomcat desactualizado con `/manager/html` expuesto

Campo	Valor
ID del hallazgo	H-04
Fase	☒ Escaneo ☐ Reconocimiento ☐ Explotación ☐ Post-explotación
Descripción	Tomcat 9.0.7 (2019) publica el panel de administración en <code>/manager/html</code> (HTTP 401). Se probaron 76 credenciales por defecto de SecLists sin éxito, por lo que no se escaló por esta vía, pero el panel queda disponible para un ataque de diccionario posterior.
Componente afectado	Apache Tomcat 9.0.7 — <code>/manager</code> , <code>/host-manager</code>
Categoría (CWE)	CWE-1392 (Use of Default Credentials) / OWASP A07:2021
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	<code>curl -u <user>:<pass> http://<IP>:8080/manager/html</code> (76 combinaciones)
Herramienta utilizada	curl + SecLists <code>tomcat-betterdefaultpasslist.txt</code>
Impacto en la tríada CIA	☐ Confidencialidad ☐ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Deshabilitar el manager en entornos productivos o restringirlo por IP; mantener Tomcat actualizado.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-05 — Subida de archivos sin validación de tipo → RCE (Vulniversity)

Campo	Valor
ID del hallazgo	H-05
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación

Campo	Valor
Descripción	El formulario en <code>/internal/index.php</code> valida la extensión del archivo con una <i>blacklist</i> incompleta. Se comprobó empíricamente que rechaza <code>.txt</code> , <code>.gif</code> , <code>.php</code> , <code>.html</code> (entre otras) y acepta <code>.phtml</code> , extensión que Apache ejecuta como PHP. Subiendo <code>cmd.phtml</code> se obtuvo ejecución remota de comandos como <code>www-data (uid=33)</code> .
Componente afectado	Aplicación web en <code>:3333/internal/</code> (Apache + PHP)
Categoría (OWASP / CWE)	OWASP A04:2021 Unsafe Design / CWE-434 (Unrestricted Upload of File with Dangerous Type)
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>curl -F "file=@shell.phtml" -F "submit=Submit" http://<IP>:3333/internal/index.php → ?c=id → uid=33(www-data)</code>
Herramienta utilizada	curl, SecLists (sonda de extensiones), tmux/nc
Impacto en la tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Validar por <i>whitelist</i> de tipos MIME reales (<code>finfo</code>), renombrar el archivo con nombre aleatorio, guardarlo fuera del docroot y servirlo con un manejador que nunca lo ejecute; deshabilitar la ejecución de PHP en el directorio de subidas (<code>php_admin_flag engine off</code>).
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-06 — Archivos subidos accesibles y ejecutables públicamente

Campo	Valor
ID del hallazgo	H-06
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Los archivos cargados quedan en <code>/internal/uploads/</code> y son directamente accesibles vía HTTP y ejecutables, lo que permite reutilizar la webshell en cualquier momento.
Componente afectado	<code>/var/www/html/internal/uploads/</code>
Categoría (CWE)	CWE-552 (Files or Directories Accessible to External Parties)
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico

Campo	Valor
Evidencia (captura / comando)	<code>curl http://<IP>:3333/internal/uploads/cmd.phtml?c=id</code>
Herramienta utilizada	curl
Impacto en la tríada CIA	☒ Confidencialidad ☒ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Servir subidas a través de un script con control de acceso y sin ejecución; permisos <code>0755</code> sobre el directorio y propiedad distinta del usuario del servidor web.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-07 — Contraseña débil en SSH (usuario `jan`)

Campo	Valor
ID del hallazgo	H-07
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	El usuario <code>jan</code> (confirmado previamente por enumeración SAMR sobre SMB) utiliza una contraseña débil que fue recuperada por ataque de diccionario dirigido con hydra. Las notas en <code>/development/j.txt</code> ya lo anticipaban ("I was able to crack your hash really easily").
Componente afectado	OpenSSH 8.2p1 — autenticación por contraseña
Categoría (CWE)	CWE-521 (Weak Password Requirements) / OWASP A07:2021
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	<code>hydra -l jan -P <lista> -t 4 -f ssh://<IP> → login: jan password: ***</code> (ver evidencias/explotacion/)
Herramienta utilizada	hydra 9.7
Impacto en la tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Longitud mínima y rotación de contraseñas; deshabilitar autenticación por contraseña en SSH y usar solo claves públicas; instalar fail2ban/MaxAuthTries.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-08 — Llave privada de `kay` legible por cualquier usuario

Campo	Valor
ID del hallazgo	H-08
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	<code>/home/kay/.ssh/id_rsa</code> tiene permisos <code>-rw-rw-r--</code> (legible por todos). Estando dentro como <code>jan</code> , se copió la llave y se descubrió su passphrase mediante cracking offline.
Componente afectado	Sistema de archivos — <code>/home/kay/.ssh/</code>
Categoría (CWE)	CWE-732 (Incorrect Permission Assignment for Critical Resource)
CVE (si aplica)	—
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	<code>scp jan@<IP>:/home/kay/.ssh/id_rsa . → chmod 600 id_rsa → ssh -i id_rsa kay@<IP></code>
Herramienta utilizada	scp, OpenSSH
Impacto en la tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	<code>chmod 600 ~/.ssh/id_rsa</code> en todas las claves; auditoría de permisos con <code>find /home -perm -o+r -name "id_rsa"</code> .
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-09 — Contraseña de servicio en archivo de respaldo + sudo sin restricción

Campo	Valor
ID del hallazgo	H-09
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	<code>/home/kay/pass.bak</code> contiene la contraseña en texto plano. El usuario <code>kay</code> pertenece al grupo <code>sudo</code> (<code>27(sudo)</code>), por lo que con esa contraseña se obtiene <code>uid=0(root)</code> y se lee <code>/root/flag.txt</code> .
Componente afectado	<code>/home/kay/pass.bak</code> + <code>/etc/sudoers</code> (grupo <code>sudo</code>)
Categoría (CWE)	CWE-312 (Cleartext Storage of Sensitive Information) + CWE-269 (Improper Privilege Management)
CVE (si aplica)	—

Campo	Valor
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>cat /home/kay/pass.bak → sudo -S id → uid=0(root)</code>
Herramienta utilizada	OpenSSH, sudo
Impacto en la tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Eliminar respaldos en texto plano; rotar la contraseña; limitar <code>sudo</code> con restricciones de comando en <code>/etc/sudoers.d/</code> .
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-10 — Apache Struts 2.5.12 desplegado en Tomcat (no explotado)

Campo	Valor
ID del hallazgo	H-10
Fase	☒ Escaneo ☐ Reconocimiento ☐ Explotación ☐ Post-explotación
Descripción	En <code>/opt/apache-tomcat-9.0.7/webapps/</code> se encuentra <code>struts2-rest-showcase-2.5.12.war</code> , desplegado y accesible (HTTP 303 en el directorio). Struts 2.5.12 es afectado por CVE-2017-5638 (S2-045) , RCE vía cabecera <code>Content-Type</code> . Coincide con la pista de <code>dev.txt</code> . No se explotó : el alcance ya había sido cubierto con H-05/H-07/H-09 y la explotación superaría lo necesario para la evidencia.
Componente afectado	Struts2 REST Showcase 2.5.12 en Tomcat :8080
Categoría (CWE)	CWE-94 (Code Injection) / OWASP A03:2021 Injection
CVE (si aplica)	CVE-2017-5638 (S2-045), CVE-2017-9805 (S2-052)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>ls /opt/apache-tomcat-9.0.7/webapps/</code> , <code>curl -o /dev/null -w "%{http_code}" http://<IP>:8080/struts2-rest-showcase-2.5.12/</code>
Herramienta utilizada	curl, enumeración post-explotación
Impacto en la tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Eliminar las aplicaciones de ejemplo de producción (<code>examples</code> , <code>showcase</code>); actualizar Struts a 2.5.16+ o aplicar el parche del advisory.

Campo	Valor
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

H-11 — Configuración de seguridad web incompleta (nikto)

Campo	Valor
ID del hallazgo	H-11
Fase	☒ Escaneo ☐ Reconocimiento ☐ Explotación ☐ Post-explotación
Descripción	nikto reporta Apache 2.4.41 desactualizado, fuga de inodes por ETag (CVE-2003-1418) y ausencia de las cabeceras <code>Permissions-Policy</code> , <code>X-Content-Type-Options</code> , <code>Strict-Transport-Security</code> , <code>Referrer-Policy</code> y <code>Content-Security-Policy</code> .
Componente afectado	Apache 2.4.41 — cabeceras HTTP
Categoría (CWE)	CWE-693 (Protection Mechanism Failure) / OWASP A05:2021
CVE (si aplica)	CVE-2003-1418 (ETag/inode)
CVSS estimado	☒ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	<code>nikto -h http://<IP>:3333 \ tee bitacora/vulniversity_nikto.txt</code>
Herramienta utilizada	nikto 2.6.0
Impacto en la tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Agregar las cabeceras faltantes, desactivar <code>FileETag</code> , mantener Apache actualizado.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

6.4 Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H-05, H-09
Alto	5	H-03, H-06, H-07, H-08, H-10
Medio	3	H-01, H-02, H-04
Bajo	1	H-11

Severidad	Cantidad	ID de hallazgos
Total	11	

Cadena de explotación resumida:

1. **Basic Pentesting** — `nmap` → `gobuster` → `/development/` (H-01) → share SMB anónimo (H-02) → enumeración SAMR (`jan` , `kay` , `ubuntu`) → `hydra` (H-07) → shell como `jan` → llave privada legible de `kay` (H-08) → `pass.bak` + grupo `sudo` (H-09) → **root**.
2. **Vulniversity** — `nmap` → `gobuster` → `/internal/` → sonda de extensiones → `bypass` `.phtml` (H-05/H-06) → RCE como `www-data` → flag de usuario.

6.5 Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones) — priorizadas

1. **[Crítico] Bloquear la ejecución de archivos subidos:** whitelist de tipos con `finfo` , renombrado aleatorio, directorio de subidas fuera del docroot y `php_admin_flag engine off` (mitiga H-05 y H-06).
2. **[Crítico] Eliminar contraseñas en texto plano** (`pass.bak`) y rotar la de `kay` ; restringir `sudo` a comandos específicos (mitiga H-09).
3. **[Alto] Actualizar componentes:** Tomcat 9.0.7 → 9.0.x actual, Apache 2.4.41 → 2.4.6x, Struts 2.5.12 → 2.5.16+ o eliminar el showcase (mitiga H-03, H-04, H-10, H-11).
4. **[Alto] Cerrar AJP 8009** en firewall o restringirlo a `127.0.0.1` (mitiga H-03).
5. **[Alto] Corregir permisos:** `chmod 600` en todo el material de `/home/*/` (mitiga H-08).
6. **[Alto] SSH endurecido:** deshabilitar `PasswordAuthentication` , usar solo claves, `MaxAuthTries 3` , instalar `fail2ban` (mitiga H-07).
7. **[Medio] Deshabilitar `Options -Indexes`** y los shares SMB anónimos (mitiga H-01, H-02).
8. **[Medio] Cabeceras HTTP:** CSP, HSTS, X-Content-Type-Options, Referrer-Policy, Permissions-Policy; desactivar `FileETag` (mitiga H-11).

Recomendaciones administrativas (políticas y procesos)

- **Gestión de credenciales:** política de contraseñas con longitud mínima y prohibitivo de reutilización; auditoría trimestral de cuentas locales y revisión de `/etc/shadow` con herramientas de cracking interno (como ya hacía el equipo según `j.txt`).
- **Inventario y ciclo de vida de activos:** registro de versiones de Apache/Tomcat/Struts con alertas de EOL y ventana mensual de parcheo.
- **Capacitación:** los desarrolladores dejaron notas internas y credenciales en el docroot; incluir formación en manejo de secretos y en revisión de código (SAST) antes de publicar.
- **Revisión periódica de permisos y shares** (SMB, FTP, directorios web) con chequeo automático.
- **Registro y monitoreo:** habilitar `mod_security` , logs de acceso al manager de Tomcat y alertas ante uploads o peticiones AJP inusuales.

- **Pruebas de seguridad periódicas:** repetir este ejercicio cada semestre y mantener las ROE documentadas.

7. PARTE III — Protocolo de contingencia

Escenario de falla

Durante la intervención se utilizaron técnicas de fuerza bruta (`hydra`) y de subida de archivos con ejecución remota. El escenario de falla más probable es que una de esas acciones —o un fuzzing mal acotado— provoque **caída del servicio web o del demonio SSH** en un entorno que no sea de laboratorio (producción de INSECUR S.A.), o que una webshell quede persistida en un servidor olvidado. Un segundo escenario: el análisis de tráfico por `tcpdump` sobre la tarjeta equivocada interrumpa la conectividad de la red corporativa.

Impacto sobre la continuidad del negocio

- **Portal web y aplicaciones internas** caídos → pérdida de disponibilidad de los canales de atención al cliente y de las operaciones que dependen de ellos.
- **SSH inaccesible** → imposibilidad de administración remota; el equipo de infraestructura debe recurrir a acceso presencial o consola.
- Duración estimada del impacto: **entre 30 y 120 minutos** si se detecta a tiempo; superior a 4 horas si la webshell persistida se activa de forma no controlada.

Plan de respuesta

1. **Activación:** detección mediante alertas de WAF/IDS por tráfico de fuerza bruta o por artefactos `.phtml` /webshells nuevos en el docroot; reporte del equipo de monitoreo o del responsable de turno.
2. **Contención (primeros 15 minutos):** aislar el host afectado del balanceador, bloquear el origen atacante en el firewall, suspender las cuentas comprometidas y detener los servicios afectados si corresponde. Preservar imágenes forenses (memoria y disco).
3. **Recuperación:** restaurar el servicio desde el último backup verificado o desde un servidor espejo; aplicar los parches de H-03/H-05/H-10 antes de reactivar; rotar todas las credenciales expuestas; verificar la integridad de los archivos publicados.
4. **Comunicación:** notificación inmediata a Dirección de TI y al responsable del negocio; comunicación a clientes si hubo exposición de datos; autoridades cuando la normativa lo exija (Ley 25.326 de Protección de Datos Personales si hay datos personales involucrados).
5. **Post-mortem:** informe de incidente dentro de las 48 h con línea de tiempo, causa raíz, acción correctiva y preventiva; lecciones aprendidas incorporadas a la política de seguridad y a la próxima revisión de las ROE.

RTO y RPO estimados

- **RTO (Recovery Time Objective):** 2 horas para el portal web; 1 hora para el servicio SSH de administración.

- **RPO (Recovery Point Objective):** 24 horas (frecuencia de respaldos diarios del docroot y de la base de datos).

8. Anexos

Anexo A — Bitácora de comandos

Archivos `bitacora/` en la branch:

- `nmap_inicial.txt`, `nmap_puertos.txt` — Basic Pentesting
- `nmap_inicial_v2.txt`, `vulnversity_nmap_puertos.txt`, `vulnversity_nmap_servicios.txt`
- `gobuster.txt`, `gobuster_8080.txt`, `gobuster_80_raft.txt`, `vulnversity_gobuster.txt`
- `vulnversity_nikto.txt`
- `hydra_ssh.txt`, `hydra_jan.txt`, `hydra_jan_dirigida.txt`
- `README.md` — resumen de comandos y hallazgos por fase
- `clase_09_20261007.txt` — export de comandos de la sesión con redacción de secretos (Anexo A de la guía)

Anexo B — Capturas de pantalla

Carpeta `evidencias/` con subcarpetas por fase (`reconocimiento` , `escaneo` , `explotacion` , `post`), nombradas `<fase>_<hallazgoID>.png` :

Archivo	Hallazgo	Contenido
<code>reconocimiento/</code> <code>reconocimiento_H-00_perfil_thm.png</code>	—	Perfil THM <code>valemoyafernandez</code> (username visible)
<code>reconocimiento/</code> <code>reconocimiento_H-00_sala_pf_completada.png</code>	—	Pentesting Fundamentals completada (5 tasks)
<code>reconocimiento/</code> <code>reconocimiento_H-00_perfil_lsala.png</code>	—	Perfil con salas completadas y streak
<code>reconocimiento/</code> <code>reconocimiento_H-05_sala_vulnversity_ip.png</code>	H-05	Sala Vulnversity con IP <code>10.67.184.183</code>
<code>reconocimiento/</code> <code>reconocimiento_H-07_sala_basic_ip.png</code>	H-07	Sala Basic Pentesting con IP <code>10.67.180.56</code>
<code>escaneo/escaneo_H-11_nmap_vulnversity.png</code>	H-11	<code>nmap -sC -sV -p-</code> sobre Vulnversity
<code>escaneo/escaneo_H-05_form_upload.png</code>	H-05	Formulario Upload en <code>:3333/internal/index.php</code>
<code>explotacion/</code> <code>explotacion_H-07_hydra_resultado.png</code>	H-07	hydra → login: jan password: <code>***</code> (credencial recuperada)

Archivo	Hallazgo	Contenido
post/post_H-09_root.png	H-09	uid=0(root) + ls -la /root/ con flag.txt (credencial redactada)

Anexo C — Hashes de las flags obtenidas

Formato `flag_id sha256_hash` (la flag en claro nunca se publica):

flag_id	sha256
PF-01 (Pentesting Fundamentals, Task 5)	583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6
VV-01 (Vulniversity — flag de usuario)	d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
BP-01 (Basic Pentesting — /root/flag.txt , 1017 bytes)	852afba51134631548962400b2970b958e1a5b3cf52c48ee1433d9930fcb2a21

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante	Fecha
Valentin Moya	07/10/2026